

SIMATS ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ITA1434 – ETHICAL HACKING

ASSIGNMENT 1

Name: D K Sumalatha

Reg no: 192424023

Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Course Outcome: CO1 – Foundational concepts of ethical hacking, types of hackers, ethical principles, legal frameworks and responsible disclosure

Task 1 – Formulate the Enquiry and Framework Blueprint

1.1 Problem restatement

The university is about to upgrade its student portal, learning-management system (LMS), e-mail service and campus network. Before the upgrade it wants these systems tested by ethical hackers. The danger is that, without governance, a well-meaning test can become unauthorized access, damage a live system, expose personal data or leak a vulnerability before it is fixed. Our team has therefore been asked to build a governance framework, not a tool list. The framework is called **UASAP-EF** (University Authorized Security-Assessment Programme – Engagement Framework). It separates three questions that are often confused:

Question	Meaning in this framework	Owner
Is it authorized?	Does a named person with the right to approve have a signed, recorded approval for this exact scope and period?	Programme Owner (CISO) + System Owner
Is it legal?	Does the activity stay inside the IT Act 2000, the DPDP Act 2023 and, where relevant, the US CFAA? Authorization from the university does not legalise an attack on a third party's system or an unsafe handling of personal data.	Legal Counsel + Data Protection Officer
Is it appropriate?	Is it consistent with the university's ethics, risk appetite and academic mission (e.g. not testing during examinations, not touching student records unnecessarily)?	Governance Board

1.2 Systems in scope (initial 20 systems)

ID	System	Group	Data class*	Criticality
SYS-001	Student portal – web front end	Student portal	P	High
SYS-002	Student portal – application server	Student portal	P	High

SYS-003	Student information database	Student portal	S	Critical
SYS-004	LMS web application (Moodle-type)	LMS	P	High
SYS-005	LMS database	LMS	P	High
SYS-006	LMS file/content store	LMS	N	Medium
SYS-007	LMS test/staging instance	LMS	N (synthetic)	Low
SYS-008	Mail gateway / spam filter	E-mail	N	High
SYS-009	Mail server (mailboxes)	E-mail	S	Critical
SYS-010	Webmail interface	E-mail	P	High
SYS-011	Campus firewall	Network	N	Critical
SYS-012	Core switch	Network	N	Critical
SYS-013	Wi-Fi controller	Network	N	High
SYS-014	DNS / DHCP server	Network	N	High
SYS-015	VPN gateway	Network	N	High
SYS-016	Single sign-on / directory (LDAP/AD)	Identity	S	Critical

SYS-017	Backup server	Infrastructure	S	High
SYS-018	HR / payroll system	Administration	S	Critical (excluded in phase 1)
SYS-019	Examination system	Academic	S	Critical (excluded in exam weeks)
SYS-020	University public website	Web	N	Medium

**Data class: N = no personal data, P = personal data, S = sensitive personal / financial / credential data.*

1.3 Stakeholders

Stakeholder	**Role in the programme**	**Main concern**
Vice-Chancellor / Registrar	Executive sponsor	Reputation, legal exposure
CISO (Programme Owner)	Final approval authority for engagements	Risk to live services
Governance Board (our team)	Maintains framework, reviews exceptions	Consistency and fairness
System Owners (department heads)	Request tests, accept risk, fix findings	Downtime, student impact
Data Protection Officer (DPO)	Reviews any test touching personal data	DPDP compliance
Legal Counsel	Reviews contracts, NDAs, external assessors	Liability
Internal testers (approx. 50 staff)	Execute tests	Clear permission, safety
External / third-party assessors (future)	Execute tests under contract	Scope clarity, indemnity

Students and staff (data subjects)	Their data may be exposed during tests	Privacy
IT Operations / SOC	Monitor and restore services	Not mistaking tests for attacks

1.4 Expected activities and constraints

- **Activities:** vulnerability scanning, authenticated web-application testing, configuration review, network mapping, password-policy review, phishing-awareness simulation (later phase), report writing and coordinated disclosure.
- **Constraints:** (C-a) about 20 systems and 50 staff initially, but the design must scale to the whole university and external assessors; (C-b) systems hold personal data; (C-c) live systems must not be damaged; (C-d) testing may be requested by any department; (C-e) no live exploitation in this assignment, only design/documentation/isolated lab; (C-f) Indian law applies by default, other laws apply where an external party or foreign service is involved.

1.5 Engagement-governance requirements

Req.	Requirement (formalised from the scenario)	Addressed by
R1	No test may start without written, recorded, in-date authorization from an approver with authority over every system tested.	Task 6, Task 8 (AF)
R2	Every engagement has a unique ID, a named scope list of SYS-IDs, test window and rules of engagement.	Task 5
R3	Requests outside the scope register or window must be detected and rejected automatically or by checklist.	Task 5
R4	The framework must show which law governs each control (IT Act, DPDP Act, CFAA).	Task 4
R5	Attackers must be classified consistently so that tests simulate realistic threats and unauthorized actors are not confused with testers.	Task 2
R6	Testers must follow a code of conduct with checks that separate acceptable, borderline and unacceptable actions.	Task 3

R7	Hands-on testing that could harm live systems must first be rehearsed in an isolated lab.	Task 7
R8	Findings must be reported in a structured format and disclosed through a coordinated process with fixed timelines.	Tasks 6, 8
R9	The framework must scale from one department to the whole university and to third-party assessors without redesign.	Task 10
R10	The framework must be adaptable to changed requirements (continuous testing, stricter data rules, shorter disclosure).	Task 11

1.6 Framework blueprint

Figure 1 shows how the components cooperate. A request enters at the top. It cannot move forward until authorization (C1), scope/RoE (C2) and legal checks (C3) agree. The threat model (C4) and code of conduct (C5) shape what testers may simulate and how they behave. Hands-on work happens only in the isolated lab (C6). Output is a structured finding (C7) that drives the disclosure process (C8). Everything is written to one audit log.

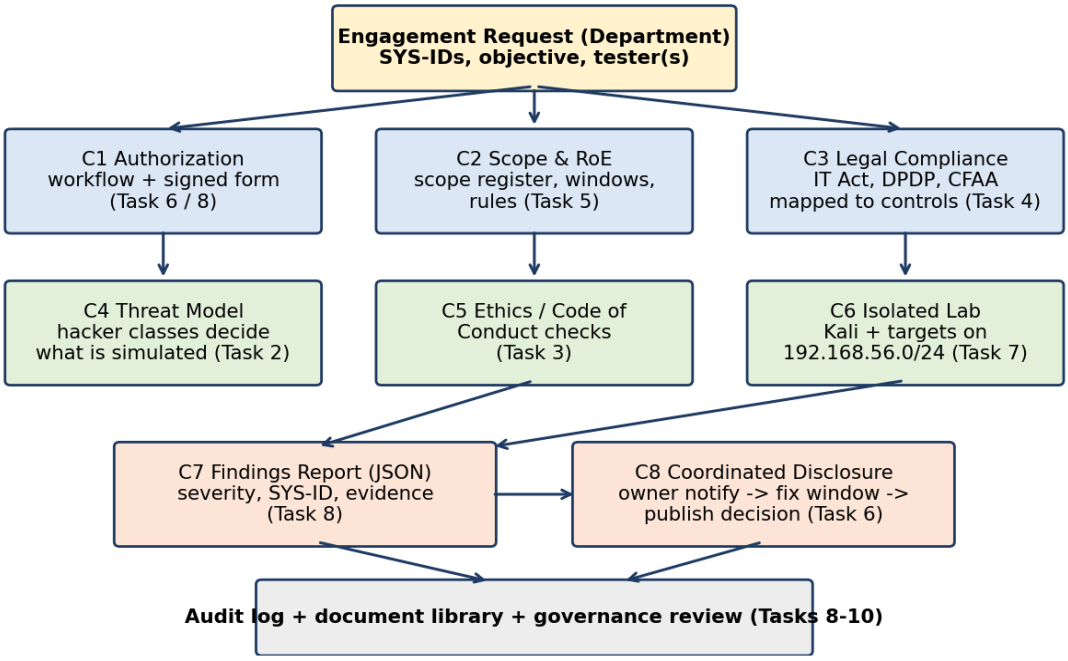


Figure 1: Requirements-to-governance blueprint of UASAP-EF

1.7 Enquiry questions

No.	Enquiry question the framework must answer	Where answered
Q1	Who is allowed to authorize a test, and what proof must exist before it starts?	Tasks 5, 6, 8
Q2	What exactly is in scope and out of scope, and how is an out-of-scope request detected?	Task 5
Q3	Which laws apply to a test (especially one touching personal data) and which control enforces each?	Task 4
Q4	Which type of attacker is being modelled and how do we tell a tester from a malicious actor?	Task 2
Q5	How do we stop ethical testers from behaving unethically or exceeding permission?	Task 3
Q6	How and when are discovered vulnerabilities disclosed, and who decides?	Task 6
Q7	How does an isolated lab keep hands-on practice contained and authorized?	Task 7
Q8	Does the framework still work when the programme grows or requirements change?	Tasks 10, 11

1.8 Design criteria (acceptance criteria)

ID	Design criterion	Acceptance test (framework passes if…)
DC1	**Authorization-first**	100% of test cases without valid authorization are blocked (TC-01, TC-02).
DC2	**Legal traceability**	Every legal requirement in Task 4 links to at least one control, and every control to a legal or ethical source.
DC3	**Containment / safety**	Lab operations prove no route to non-lab networks; live-system tests are never started without lab rehearsal.
DC4	**Consistency**	Two reviewers classify the same actor/action the same way using the written criteria (Tasks 2, 3).
DC5	**Scalability**	Approval turnaround for the large programme stays below 8 working hours on average (Task 10).
DC6	**Auditability**	Every approval, status change and disclosure decision is logged with who, what and when.

DC7	**Usability**	A new tester can complete the pre-engagement checklist in under 15 minutes using the document library.
DC8	**Extensibility**	A changed requirement can be absorbed by modifying or adding a component, not redesigning all (Task 11).

1.9 Rationale

A layered design was chosen because the scenario's risks (unauthorized access, legal exposure, damage, unclear scope, uncoordinated disclosure) are different failures, each needing its own control. A single long policy would be hard to test. Separate components with defined inputs and outputs can be tested independently (Tasks 3, 5, 6, 8) and together (Task 9). The trade-off is more documents to maintain; this is reduced by a common document library and one audit log.

Task 2 – Hacker Threat Model and Classification

2.1 Classification criteria

An actor is classified by five attributes, applied in a fixed order so that results are repeatable (DC4).

Attr.	Name	Values
A1	Authorization	Written (Y) / None (N) / Implied or disputed (P)
A2	Primary intent	Protect, Curiosity, Profit, Ideology, Espionage/Strategic, Grievance
A3	Capability	L = low (uses ready-made tools), M = medium (adapts tools), H = high (writes exploits), A = advanced/persistent (resources, zero-days)
A4	Affiliation	Internal (student/staff/contractor with access) / External
A5	Disclosure behaviour	Reports privately / Publishes / Sells or exploits / Hides

Decision order: (1) If A1 = Y and the actor stays inside scope → White-hat. (2) If A1 ≠ Y and A2 = Espionage with A3 = A → State-sponsored. (3) If A2 = Ideology → Hacktivist. (4) If A4 = Internal and misuse of legitimate access (malicious or careless) is the main route → Insider. (5) If A2 = Profit/Grievance and harm is done → Black-hat. (6) If A3 = L and tools are used without understanding → Script kiddie. (7) If A1 = N but intent is Curiosity/Protect and the actor discloses → Grey-hat. Naming convention: **ACTOR-<Class>-<Origin>-<Capability>** e.g. ACTOR-GREY-INT-M.

2.2 Threat model and mapping table

Type	Motivation	Typical capability	Likely targets at the university	Treatment in programme
White-hat (authorized tester)	Protect, professional duty	M–H	Any in-scope system under RoE	Engagement role; follows Tasks 3, 5, 6
Black-hat (criminal)	Money, theft, grievance	M–H	Student DB (SYS-003), payroll (SYS-018), mail (SYS-009),	Primary adversary simulated in tests

			exam system (SYS-019)	
Grey-hat	Curiosity, reputation, 'helping'	M	Student portal, LMS, public website	Treated as unauthorized; encourage coordinated reporting
Script kiddie	Fun, status	L	Public website (SYS-020), webmail (SYS-010), Wi-Fi	Baseline: scanning/default-password tests
Hacktivist	Ideology, protest	L–M	Public website defacement, DoS on portal, leaks of admission data	Test DoS resilience (design level only)
Insider (malicious or negligent)	Grievance, money, error	L–H (has access)	Student DB, LMS grades, backup server, SSO	Privilege review, logging, least privilege
State-sponsored / APT	Espionage, research theft	A	Research data, SSO (SYS-016), mail, VPN (SYS-015)	Assume breach scenario; long-term monitoring

2.3 Borderline actor – alternative classifications

Borderline actor: a second-year student who, without permission, runs a free scanner against the student portal, notices a flaw that lets any logged-in student view another student's marks, views only his own friend's record to confirm it, and then e-mails the IT helpdesk with the details.

Option	Classification	Reasoning	Weakness
Alt-1	Script kiddie (ACTOR-SK-INT-L)	Used a free scanner; no custom exploit	Ignores intent: he reported rather than exploited, and did understand the flaw

Alt-2	Insider (ACTOR-INS-INT-L)	He is a student with legitimate login; flaw abused from inside	'Insider' implies misuse of granted privilege; he used a flaw, not granted access
Alt-3	Black-hat	Accessed another record without permission – an offence under IT Act s.43/66	Black-hat requires harmful or profit motive; none exists
Final	**Grey-hat with insider flag (ACTOR-GREY-INT-L/M)**	Applying the decision order: A1 = N, A2 = Curiosity, disclosed privately (A5) → rule (7) fires after rules (1)–(6) fail	Still an unauthorized act; flagged for conduct review, not criminal referral

Justification: the final label keeps the legal truth (access was unauthorized, so he cannot be called white-hat) while recognising that intent and disclosure behaviour were responsible. The 'insider' flag records that he has legitimate credentials, which affects remediation (review access controls). The rejected alternatives were rejected because each ignored an attribute (intent for Alt-1 and Alt-3, privilege misuse for Alt-2). This case also shows why the university should publish a safe-reporting channel (Task 6) so grey-hat behaviour is converted into reports.

Task 3 – Ethics and Code-of-Conduct Module

3.1 Ethical principles

ID	Principle	Meaning for a tester	Source / reason
E1	Written authorization	No action before signed authorization exists and is recorded	IT Act s.43, 66; CFAA 'without authorization'
E2	Agreed scope	Only listed SYS-IDs, IPs, techniques and windows	Prevents collateral damage
E3	Confidentiality	Findings, credentials and data seen are not shared outside the engagement	IT Act s.72, NDA
E4	Integrity	Do not alter, delete or plant data; do not hide traces of own actions	IT Act s.65, 66
E5	Avoid harm	Stop if instability, safety or privacy impact is seen; prefer least intrusive method	Professional duty
E6	Honest reporting	Report what was found including mistakes; no exaggeration or concealment	Trust
E7	Data minimisation	Touch the least personal data needed; never retain it after the engagement	DPDP Act 2023
E8	Professional competence	Use only techniques the tester understands; ask for help rather than guess	Reduces accidental damage

3.2 Rules and automated/manual checks

Rule	Check	When	Action on failure
CR-1	Authorization ID present and status = APPROVED in register	Before start and at each phase	Block; notify Engagement Monitor
CR-2	Target IP/FQDN matches scope register for this engagement	Before every scan or test run	Reject target; log as scope violation
CR-3	Current time inside testing window	Continuously	Pause testing

CR-4	Technique is on the permitted list (RoE §5.4)	Before use	If prohibited → stop; if unlisted → escalate (borderline)
CR-5	Personal data viewed is limited to proof-of-access (max 5 records, masked)	During evidence capture	Delete excess; report to DPO
CR-6	No data leaves the engagement evidence store	At close	Hash evidence, destroy copies, sign closure form
CR-7	Two-person rule for high-risk actions (e.g. admin-level access on critical system)	Before action	Needs lead tester + Monitor approval
CR-8	Honest-reporting check: every command log entry appears in report appendix	At report review	Return report to tester

3.3 Decision rules

```
IF no valid authorization OR target not in scope OR outside window  ->
UNACCEPTABLE (stop, log, escalate)
ELSE IF technique in prohibited list OR data exfiltrated/altered/deleted ->
UNACCEPTABLE
ELSE IF technique not listed OR personal data more than CR-5 limit OR impact uncertain
-> BORDERLINE
      (pause, ask Engagement Monitor within 1 hour; proceed only with written yes)
ELSE -> ACCEPTABLE
```

3.4 Scenario test cases

Case	**Action**	**Expected class**	**Code-of-conduct response**	**Result**
S1	Scanning SYS-004 inside window with signed AF-014	Acceptable	Proceed; log commands	Pass

S2	Running a vulnerability scanner at low rate on SYS-001 as listed in RoE	Acceptable	Proceed	Pass
S3	Reporting a critical finding to Monitor within 24 h	Acceptable	Start disclosure workflow	Pass
S4	Finding a SQL injection and viewing 3 masked student records as proof	Acceptable (within CR-5)	Record masked proof; inform DPO	Pass
S5	Tester sees SYS-019 (exam system) on same subnet; wants to 'just check' it	Borderline → unacceptable if not in scope	CR-2 rejects; request scope amendment	Pass
S6	Brute-force login test not listed in RoE	Borderline	CR-4 escalate; Monitor decides in writing	Pass
S7	Tester views 200 records to 'check how bad it is'	Borderline → exceeds CR-5	Stop, purge excess, DPO informed	Pass
S8	Dumping the student DB to laptop	Unacceptable	Stop engagement, revoke access, Legal review	Pass
S9	Testing a vendor-hosted mail provider's infrastructure without its permission	Unacceptable	Out-of-scope, third-party law applies (CFAA/foreign law); stop	Pass
S10	Deleting logs after test to 'clean up'	Unacceptable	Violates E4; incident raised	Pass

Evidence that the rules separate acceptable from unacceptable: the 10 cases were classified by two team members independently using only Section 3.3. Both gave the same class for all ten cases (agreement 10/10), including the three borderline cases that were resolved by escalation rather than by guesswork.

3.5 How the module preserves trust and lawfulness

- Testers know in advance what is allowed, so honest mistakes are caught early, not punished afterwards.
- System owners trust the programme because every action is bounded by CR-1 to CR-3 and is logged.

- Students and staff are protected by CR-5 and CR-6 (data minimisation and destruction).
- Legal exposure is reduced because the checks mirror the legal tests: authorization, scope, integrity and confidentiality (Task 4).
- Professionalism is kept by honest-reporting (E6/CR-8) and two-person rule for risky steps.

Task 4 – Legal-Compliance Mapping

Note: provisions are summarised from the Information Technology Act, 2000 (as amended in 2008), the Digital Personal Data Protection Act, 2023 and 18 U.S.C. §1030. Penalty figures should be re-checked against the latest official text before use in a real contract.

4.1 Offences, obligations and penalties

Law / section	**Offence or obligation**	**Penalty (summary)**	**Relevance to engagement**
IT Act s.43(a)	Accessing a computer/network without permission of the owner	Compensation to the affected person (adjudicating officer)	Core reason for written authorization
IT Act s.43(b)-(d)	Downloading/copying data, introducing virus, damaging system	Compensation	Test must not copy data or damage systems
IT Act s.43(f),(g)	Denying access to authorised person; assisting unauthorised access	Compensation	DoS testing and sharing credentials restricted
IT Act s.43A	Body corporate negligent in protecting sensitive personal data	Compensation to affected person	University must secure data used in tests
IT Act s.65	Tampering with computer source documents	Up to 3 years and/or fine up to Rs 2 lakh	No altering source/config outside lab
IT Act s.66	Doing any s.43 act dishonestly or fraudulently	Up to 3 years and/or fine up to Rs 5 lakh	Turns unauthorized testing into a crime
IT Act s.66C / 66D	Identity theft; cheating by personation (e.g. using stolen credentials / phishing)	Up to 3 years + fine up to Rs 1 lakh	Phishing simulations and credential use need explicit approval

IT Act s.69	Interception/monitoring only by competent government authority	Up to 7 years + fine	Testers must not capture live user traffic outside the lab
IT Act s.70	Unauthorised access to protected systems	Up to 10 years + fine	Check whether any in-scope system is notified as protected
IT Act s.72 / 72A	Breach of confidentiality / disclosing personal information in breach of contract	s.72: up to 2 years or fine up to Rs 1 lakh; s.72A: up to 3 years or fine up to Rs 5 lakh	NDA and confidentiality for testers and assessors
IT Act s.84B/84C	Abetment / attempt	Half the punishment of main offence	Persons who help an unauthorised tester are liable
CERT-In Directions 2022	Report specified cyber incidents to CERT-In within 6 hours	Action under s.70B	Real incident found during test triggers reporting duty
DPDP Act 2023 s.8	Data fiduciary must keep reasonable security safeguards and report breaches	Penalty up to Rs 250 crore (failure of safeguards); up to Rs 200 crore (failure to notify breach)	Strongest driver for data-protection controls
DPDP Act 2023 s.8(7)	Erase personal data when purpose is served	Within penalty schedule	Evidence must be deleted at closure
US CFAA §1030(a)(2)	Intentionally accessing without/exceeding authorization and obtaining information	Up to 1 year; up to 5 years if aggravated	Relevant if US-based assessors or US-hosted services are involved
US CFAA §1030(a)(5)	Knowingly causing damage to a protected computer	Up to 10 years (first offence, intentional damage)	Damage to live systems
US CFAA §1030(a)(7)	Threatening damage / extortion	Up to 5 years	Never threaten to publish a flaw to force payment

4.2 Comparison: IT Act 2000 and CFAA

Aspect	IT Act, 2000 (India)	CFAA (USA)
Core test	Access 'without permission of the owner or person in charge'	Access 'without authorization' or 'exceeding authorized access'
Civil vs criminal	Civil compensation (s.43) plus criminal (s.66) if dishonest/fraudulent intent	Mainly criminal with civil action allowed
Role of intent	s.66 needs dishonest/fraudulent intent; s.43 does not	Intent mostly 'intentionally' or 'knowingly'
Good-faith research	No explicit safe harbour; written authorization is the protection	No statutory safe harbour; US DOJ policy (2022) says it will not prosecute good-faith security research
Data protection	Linked to s.43A and DPDP Act 2023	Handled by other US laws, not CFAA
Lesson for us	Authorization letter naming scope is essential	'Exceeding authorization' shows why scope limits must be precise

4.3 Legal requirement → framework control

Legal requirement	Control in framework	Component / document
No access without owner's permission (s.43(a), CFAA (a)(2))	LC-1: AF must be signed by System Owner and CISO; status APPROVED before start	Task 6 workflow; Authorization Form
Do not exceed permission (CFAA 'exceeds')	LC-2: Scope register match on every target (CR-2); out-of-scope reject	RoE; Code of Conduct
No damage/denial of service (s.43(f), CFAA (a)(5))	LC-3: No DoS on live systems; lab rehearsal first; testing windows	RoE §5, Lab
No data copying (s.43(b))	LC-4: Proof-of-access only, masked, max 5 records	Code of Conduct CR-5

No tampering (s.65)	LC-5: Read-only techniques on production; changes only in lab	RoE prohibited list
No interception (s.69)	LC-6: Packet capture only in lab or on tester's own traffic	RoE, Lab
Confidentiality (s.72, 72A)	LC-7: NDA signed; encrypted evidence store; need-to-know	Document library (NDA)
Reasonable security safeguards (DPDP s.8, s.43A)	LC-8: DPO review; synthetic/masked data in tests; encrypted storage	Authorization Form data section
Breach notification (DPDP s.8(6), CERT-In)	LC-9: If real breach is found, stop test and trigger incident procedure within 6 hours	Disclosure workflow
Erasure after purpose (DPDP)	LC-10: Evidence destruction certificate at closure	Closure form
Third-party systems (any law)	LC-11: External-hosted systems out of scope unless provider's written consent	Scope register

4.4 Which laws apply when a test touches personal data?

Conclusion: (1) The **IT Act 2000** always applies, because the systems and the university are in India: s.43/66 for access, s.43A and s.72 for data. (2) The **DPDP Act 2023** applies to the university as a data fiduciary whenever digital personal data of students or staff is processed, even for testing, so a DPO-approved data-protection gate is mandatory (LC-8 to LC-10). Its penalties are the largest, so it dominates the data design. (3) **CERT-In Directions 2022** apply if a real incident is discovered. (4) The **CFAA** does not automatically apply to Indian systems tested by Indian staff; we adopt it as a **benchmark and conditional law**, applied only if an assessor is based in the US, a system is hosted in the US, or US residents' data is involved. (5) Authorization from the university does **not** override any of these laws, which is why authorization (Task 6) and legal review are separate steps.

Task 5 – Scope and Rules-of-Engagement (RoE) Document

5.1 Naming and identifiers

- Engagement ID: **ENG-<YEAR>-<GROUP>-<NNN>**, e.g. ENG-2026-LMS-001.
- System ID: **SYS-NNN** from the Scope Register (Task 1, §1.2). Each SYS-ID is bound to one hostname and IP range.
- Authorization ID: **AF-<YEAR>-<NNN>**, linked one-to-one with an engagement.
- Finding ID: **FND-<ENG>-<NN>**.

5.2 RoE document – engagement ENG-2026-LMS-001 (template with worked example)

Section	Content
1. Purpose	Assess LMS test/staging instance and web application before upgrade for common web vulnerabilities.
2. Authorization	AF-2026-014 signed by Dean (System Owner) and CISO on 04-Nov-2026; recorded in log entry LOG-0231.
3. Team	Lead tester T-07 (internal), tester T-12; Engagement Monitor: IT Operations lead.
4. In-scope systems	SYS-007 (LMS staging, 10.10.20.15, lms-stage.univ.example); SYS-004 (LMS web app – read-only/non-intrusive tests only).
5. Out-of-scope	SYS-005 LMS database (direct access), SYS-006 file store, SYS-019 exam system, SYS-018 payroll, all third-party hosted services, any student device, any production user account that is not a test account.
5.3 Testing window	Mon–Fri 22:00–05:00 IST for SYS-007; SYS-004 Sat 01:00–04:00 only. Blackout: examination weeks and admission days.
5.4 Permitted techniques	Port/service scan (rate-limited), version fingerprinting, authenticated web testing with test accounts, input-validation tests (SQL injection, XSS) on SYS-007, configuration review, password-policy review (no real passwords).
5.5 Prohibited techniques	Denial of service, brute-forcing real accounts, social engineering, physical access, data exfiltration beyond proof, modifying/deleting data, packet interception of users, pivoting from LMS to other systems, malware deployment.

6. Data handling	No real personal data; if encountered, mask, max 5 records, report to DPO; evidence stored encrypted, destroyed on closure.
7. Communications	Daily status to Monitor by 09:00; critical finding notice within 4 hours.
8. Escalation path	Level 1: Lead tester → Engagement Monitor (15 min). Level 2: CISO (1 hour). Level 3: Governance Board chair + Legal (immediate for suspected real breach or damage). Emergency stop word: 'HALT-ENG' – testing stops immediately.
9. Stop conditions	Service degradation, unexpected personal data, evidence of real attacker activity, authorization expiry.
10. Sign-off	System Owner, CISO, Lead tester, Monitor (signatures and dates).

5.3 Authorization-verification rules

Rule	**Statement**
V1	Authorization ID must exist in the Authorization Register with status APPROVED.
V2	Approver must be on the Approver List for every SYS-ID in scope (system owner of each, plus CISO).
V3	Signature must be a handwritten/e-signature plus employee ID; the signature date must be on or before start date.
V4	Validity: start ≤ today ≤ end, and total duration ≤ 30 days (renewal needs new sign-off).
V5	Scope list on the AF must be identical to the RoE scope list (SHA-256 hash of the sorted SYS-ID list matches).
V6	Testers named on the AF must match testers who log in to the lab/test accounts.
V7	Any change in scope after approval needs an amendment AF-xxx-A1 signed again.
V8	External assessors additionally need a signed contract, NDA and a legal-counsel clearance.

5.4 Detecting an out-of-scope request

A request is **in scope** only if all three tests pass: (T1) the target SYS-ID exists in the engagement scope list; (T2) the IP/FQDN given matches the register entry for that SYS-ID; (T3) the

technique is on the permitted list and the time is inside the window. Anything else is out of scope. Example: a tester asks to scan 10.10.20.0/24 'to find the LMS server'. The subnet contains SYS-006 and SYS-019 which are not listed; T1 and T2 fail, therefore the request is rejected and the tester must submit the exact IP.

5.5 Transformation: RoE → pre-engagement checklist

#	Checklist item (derived from RoE section)	Evidence	Tick
1	AF ID found, status APPROVED, dates valid (§2, V1, V4)	Register screenshot / log ID	☐
2	Approver list verified for every SYS-ID (V2)	Names + employee IDs	☐
3	Scope hash matches between AF and RoE (V5)	Hash value	☐
4	Each target IP/FQDN matches register (§4, T2)	Target list	☐
5	Out-of-scope list read and acknowledged by testers (§5)	Initials	☐
6	Test window and blackout dates confirmed with IT Operations (§5.3)	Email/ticket	☐
7	Permitted/prohibited techniques briefing done (§5.4–5.5)	Briefing record	☐
8	Test accounts created; no real accounts used (§6)	Account list	☐
9	Lab rehearsal completed and lab record filed (Task 7)	Lab record ID	☐
10	Backups/snapshots confirmed for system under test	Ticket	☐
11	DPO review done if any personal data may be touched (LC-8)	DPO signature	☐
12	Escalation contacts, stop word and communication schedule tested (§7–8)	Contact sheet	☐
13	NDA signed by all testers (LC-7)	NDA IDs	☐

Task 6 – Authorization and Disclosure Layer

6.1 Authorization workflow

Step	State	Actor	Output / record
1	REQUESTED	System Owner (or department)	Request form: objective, SYS-IDs, dates, testers
2	SCREENED	Governance Officer	Checks scope register, blackout dates, risk tier
3	LEGAL/DATA REVIEW	Legal Counsel + DPO (if personal data or external assessor)	Opinion note, data-protection conditions
4	APPROVED / REJECTED	CISO (and System Owner)	Decision with reasons
5	SIGNED	System Owner + CISO + Lead tester	Signed Authorization Form AF-<year>-<NNN>
6	RECORDED	Governance Officer	Entry in Authorization Register + audit log
7	ACTIVE	Lead tester	Pre-engagement checklist completed, testing begins
8	COMPLETED / REVOKED	Monitor / CISO	Closure report; revoke on any breach of rules

6.2 Responsible (coordinated) disclosure process

Day	Activity	Responsible
0	Finding recorded (JSON report FND-…) and reported privately to System Owner and CISO	Lead tester
≤ 2	Acknowledgement and assignment of owner	Governance Officer
≤ 7	Severity validated (CVSS-based) and remediation plan agreed	System Owner + CISO
Remediation window	Critical 30 days, High 60, Medium 90, Low 120 (baseline; see Task 11 for shortened values)	System Owner

Window end – 10	Reminder; extension request (once, max 50%) reviewed	Governance Board
After fix	Retest and verify fix; update status	Lead tester
After verification or window end	Disclosure decision (§6.5): internal advisory, vendor notice, CERT-In/public advisory	Governance Board

Reporting format: the Finding Report (Task 8, D3) – ID, title, SYS-ID, severity, description, impact, steps to reproduce (summarised), evidence (masked), recommended fix, timeline fields.

6.3 Comparison with full disclosure and bug bounty

Aspect	**Coordinated (chosen default)**	**Full disclosure**	**Bug bounty**
Who learns first	Owner/vendor, privately	Public immediately	Programme platform / owner
Time to fix	Fixed with agreed deadline	Attackers may exploit before fix	Depends on rewards and triage
Risk to students' data	Low	High	Medium
Cost	Staff time only	Low direct, high reputational	Reward budget + triage staff
Control over researchers	Contract / policy	None	Terms of platform
Fit for university now	Best for 20 systems	Only last resort	Possible later for public website (SYS-020)

6.4 Operations for logging and decisions

Three operations implement the layer. Each writes to the same append-only audit log (JSON lines).

```
# ops_log.py  (design-level reference implementation)
import json, time, hashlib
```

```
LOG='audit_log.jsonl';
STATES=['REQUESTED','SCREENED','REVIEWED','APPROVED','SIGNED','RECORDED','ACTIVE','COMPLETED','REVOKED','REJECTED']

def log_approval(eng_id, af_id, approver, decision, scope_ids):
   scope_hash = hashlib.sha256(','.join(sorted(scope_ids)).encode()).hexdigest()
   rec = {'ts': time.time(), 'eng': eng_id, 'af': af_id, 'approver': approver,
         'decision': decision, 'scope_hash': scope_hash}
   open(LOG,'a').write(json.dumps(rec)+'\n'); return rec

def update_status(eng_id, new_state, by):
   assert new_state in STATES

open(LOG,'a').write(json.dumps({'ts':time.time(),'eng':eng_id,'state':new_state,'by':by})+'\n')

def can_disclose(finding, today_day):
   # finding: dict from Finding Report JSON (Task 8)
   if finding['status'] == 'FIXED_VERIFIED': return 'ADVISORY_ALLOWED'
   if today_day >= finding['window_days'] and finding['severity'] in ('Low','Medium'):
      return 'ADVISORY_ALLOWED'
   if today_day >= finding['window_days']: return 'BOARD_DECISION_REQUIRED'
   return 'HOLD'
```

6.5 Rules for choosing coordinated or full disclosure

Rule	Condition	Choice
D1	Finding affects only university systems and an owner can fix	Coordinated (always default)
D2	Owner unresponsive after window + one extension and risk is Critical/High	Escalate to Board; Board may issue limited advisory (mitigation without technical detail)
D3	Vendor product flaw and vendor does not respond in 90 days (45 days after Task 11)	Report to CERT-In / coordinating body; then limited public disclosure

D4	Active exploitation by attackers already observed	Immediate mitigation; notify CERT-In within 6 hours; no waiting for window
D5	Finding exposes personal data	Never publish details; DPDP breach procedure; DPO decides on notification
D6	Technical detail would let others exploit unpatched systems	Withhold technical detail until fixed; publish summary only

6.5.1 Evidence of interaction with RoE and legal compliance

Test	**Interaction**	**Result**
I-1	Finding for SYS-005 arrives but RoE listed SYS-005 as out-of-scope → workflow flags 'out-of-scope finding'; disclosure blocked until scope amendment and legal review	Blocked correctly
I-2	Finding report includes 150 real records → code-of-conduct CR-5 + DPDP rule D5 → report rejected, evidence purged, DPO informed	Rejected correctly
I-3	Finding Critical, AF still ACTIVE, day 31 → can_disclose returns BOARD_DECISION_REQUIRED, not automatic publication	Correct
I-4	AF expired on day 30 but retest is needed → status update refused until renewal AF-A1 is signed (V4)	Correct

Task 7 – Isolated Ethical-Hacking Lab

7.1 Lab design

The lab is hosted on a single physical host (laptop/workstation, 16 GB RAM) running VirtualBox (VMware is equivalent). All virtual machines connect to one **host-only network** named vboxnet0 with the reserved private range **192.168.56.0/24**. The host-only network has no route to the Internet or to the campus network. The lab is used to rehearse tests before touching any live system and for practice by trainee testers.

7.2 Components, roles and connectivity

Component	Role	OS / image	IP (static)	Network adapters
Host	Hypervisor, host-only gateway	Windows/Linux host	192.168.56.1 (vboxnet0)	Physical NIC not bridged to guests
LAB-KALI	Tester (attacker) machine	Kali Linux 2025.x	192.168.56.10	1 × host-only
LAB-T1	Target 1 – deliberately vulnerable Linux	Metasploitable 2	192.168.56.101	1 × host-only
LAB-T2	Target 2 – web vulnerability training	Ubuntu + DVWA / OWASP Juice Shop	192.168.56.102	1 × host-only
LAB-T3 (optional)	Target 3 – Windows evaluation	Windows evaluation VM	192.168.56.103	1 × host-only
LAB-MON (optional)	Log / packet capture	Ubuntu + tcpdump	192.168.56.50	1 × host-only

The VirtualBox DHCP server for vboxnet0 is disabled and addresses are static so that the recorded configuration and the scope list always match. Address plan: .1 host, .10–.19 testers, .50–.59 monitoring, .100–.199 targets.

```
+------------------------- Host (VirtualBox) ----------------------------+
```

```
|                    vboxnet0  192.168.56.0/24 (host-only)                |
|  LAB-KALI .10 ---+---- LAB-T1 .101 (Metasploitable)                      |
|                  +---- LAB-T2 .102 (DVWA / Juice Shop)                   |
|                  +---- LAB-T3 .103 (Windows eval)                        |
|                  +---- LAB-MON .50 (capture)                             |
|  No path to campus network / Internet                                    |
+--------------------------------------------------------------------------+
```

7.3 Steps to build and record the configuration

- Create host-only network vboxnet0, set IPv4 192.168.56.1/24, disable DHCP server.
- Import Kali VM; set adapter 1 = Host-only (vboxnet0); remove all other adapters; disable shared clipboard, drag-and-drop and shared folders.
- Import target VMs; set same adapter; assign static IPs inside each guest.
- Take a clean snapshot of every VM (baseline) so the lab can be reset after each exercise.
- Run the two operations below and store output in the Lab Configuration Record (D5).
- Hash the record (SHA-256) and file it under the engagement ID.

7.4 Operations

Operation 1 – verify connectivity and isolation:

```
# verify_lab.py
import subprocess, json
LAB={'LAB-KALI':'192.168.56.10','LAB-T1':'192.168.56.101','LAB-
T2':'192.168.56.102'}
def ping(ip): return subprocess.run(['ping','-c','1','-
W','1',ip],capture_output=True).returncode==0
report={n:ping(ip) for n,ip in LAB.items()}              # expected: all True
report['internet_blocked']=not ping('8.8.8.8')           # expected: True (no route)
report['campus_blocked']=not ping('10.10.20.15')         # expected: True
print(json.dumps(report,indent=2))
assert all(report.values()), 'LAB NOT READY OR NOT ISOLATED'
```

Expected result (design-level): all lab hosts reachable, and both external pings fail. If either external ping succeeds, the lab is declared **not isolated** and testing is not allowed.

Operation 2 – record the lab setup:

```
# record_lab.sh  (run inside LAB-KALI)
{ echo "date: $(date -Is)"; hostname; ip -4 addr show; ip route; uname -a; cat /etc/os-release;
  nmap -sn 192.168.56.0/24; } > lab_record_$(date +%F).txt
sha256sum lab_record_*.txt >> lab_record_hashes.txt
```

7.5 Host-only versus NAT network

Aspect	**Host-only (vboxnet0)**	**NAT / NAT network**	**Bridged (for completeness)**
Guest ↔ guest	Yes	Yes (NAT network) / No (plain NAT)	Yes
Guest → Internet	No	Yes	Yes
Internet/campus → guest	No	No (without port forward)	Yes – exposes lab
Risk of attack leaving lab	Very low	Medium – tools could reach real hosts	High
Updates of tools	Offline updates by image	Easy	Easy
Fit with authorization rule	Everything reachable is authorized	Reachable targets exceed authorization	Poor

Chosen design: host-only. Convenience of NAT (automatic updates) is traded for a hard guarantee that nothing can leave. Updates are applied by temporarily switching Kali to NAT while all targets are powered off, then switching back and re-running Operation 1.

7.6 How the lab stays authorized and contained

- Only the 192.168.56.0/24 addresses in the Lab Record are targets; this list is the authorization for lab testing (lab AF is issued once per exercise).

- On Kali an outbound firewall rule allows traffic only to 192.168.56.0/24: iptables -P OUTPUT DROP; iptables -A OUTPUT -d 192.168.56.0/24 -j ACCEPT.
- No second network adapter; clipboard, drag-and-drop and shared folders disabled so exploits/data cannot be copied out.
- Vulnerable VMs are never exported or powered on outside the lab; snapshots are restored after each session.
- Operation 1 is mandatory at the start of each session and its result is stored in the engagement file (pre-engagement checklist item 9).
- Lab results are used to prepare, not to replace authorization: any live test still needs the Task 6 workflow.

Task 8 – Reusable Document Library

8.1 Library index

Doc	Name	Purpose	Produces structured output?
D1	Authorization Form (AF)	Written permission for one engagement	Yes – JSON/register row
D2	Scope & RoE Sheet	Scope, windows, techniques, escalation	Yes – scope list + hash
D3	Finding Report	Records one vulnerability	Yes – JSON feeding disclosure (Task 6)
D4	Disclosure Notice	Private notice to owner/vendor, later advisory	Template
D5	Lab Configuration Record	Evidence of lab setup	Yes – text + hash
D6	Engagement Closure & Evidence-Destruction Certificate	Closes engagement, confirms deletion of data	Template
D7	Non-Disclosure Agreement (NDA)	Confidentiality for tester	Template

8.2 D1 – Authorization Form: fields and defaults

Field	Type	Default	Rule
authorization_id	text	auto: AF-<year>-<NNN>	Unique
engagement_id	text	auto	Matches RoE
requesting_department	text	—	Mandatory
system_owner_name / employee_id	text	—	Must be on Approver List for each SYS-ID
scope_sys_ids	list	—	1–20 IDs, each exists in register
start_date, end_date	date	start = today	end ≥ start; (end − start) ≤ 30 days

testing_window	text	22:00–05:00 IST	Must not overlap blackout
testers	list	—	≥ 1; external → contract no. required
personal_data_involved	yes/no	no	If yes: DPO sign-off mandatory
data_classification	N/P/S	N	S → two-person rule + DPO
techniques_permitted	list	scan, config review	Cannot include prohibited items
disclosure_policy	choice	Coordinated	Only Board can change
signatures (owner, CISO, lead tester)	e-sign	—	All three needed; date ≤ start_date
status	choice	REQUESTED	Per Task 6 state machine

8.3 D3 – Finding Report: fields, structured output

Field	**Type**	**Default / rule**
finding_id	text	FND-<ENG>-<NN>
engagement_id, authorization_id	text	Must exist and be ACTIVE or COMPLETED
sys_id	text	Must be in the engagement scope list
title, description	text	Mandatory; no raw personal data
severity	Critical/High/Medium/Low	Default Medium; based on CVSS

cvss_score	number 0.0–10.0	Mandatory; maps to severity
evidence_ref	text	Masked evidence only
recommendation	text	Mandatory
discovered_on	date	Within testing window
window_days	integer	Default from severity (30/60/90/120)
status	OPEN/IN_FIX/FIXED_VERIFIED/ESCALATED	Default OPEN
personal_data_exposed	yes/no	Default no; yes triggers D5 rule

Structured output (feeds Task 6 can_disclose and Task 5 scope check):

```
{
 "finding_id": "FND-ENG-2026-LMS-001-01",
 "engagement_id": "ENG-2026-LMS-001", "authorization_id": "AF-2026-014",
 "sys_id": "SYS-007", "title": "Reflected XSS in course search",
 "severity": "Medium", "cvss_score": 6.1, "window_days": 90,
 "personal_data_exposed": false, "status": "OPEN", "discovered_on": "2026-11-10"
}
```

The other documents (D2, D4–D7) contain these minimum content blocks: D2 – sections 1–10 of §5.2; D4 – finding ID, severity, summary without exploit detail, requested fix date, contact, disclosure date; D5 – date, host list, IPs, OS versions, snapshot names, Operation 1 output, hash; D6 – evidence list, destruction method, date, signatures; D7 – parties, definition of confidential information, duration, penalties under s.72.

8.4 Validation function and test entries

```
def validate_af(af, register, blackout):
```

```
errs=[]
if not af['scope_sys_ids'] or len(af['scope_sys_ids'])>20: errs.append('scope size')
if any(s not in register for s in af['scope_sys_ids']): errs.append('unknown SYS-ID')
d=(af['end']-af['start']).days
if d<0 or d>30: errs.append('duration')
if af['personal_data'] and not af.get('dpo_signed'): errs.append('DPO missing')
if not (af['owner_signed'] and af['ciso_signed']): errs.append('signature')
return errs   # empty list = valid
```

Test	Document	Input	Type	Expected result
T1	AF	Scope SYS-007; 10-day duration; signatures complete; no personal data	Valid	Accepted
T2	AF	Duration exactly 30 days	Boundary	Accepted
T3	AF	Duration 31 days	Boundary	Rejected – 'duration'
T4	AF	Scope with exactly 20 SYS-IDs	Boundary	Accepted
T5	AF	Scope with 21 IDs / or 0 IDs	Boundary	Rejected – 'scope size'
T6	AF	SYS-099 not in register	Invalid	Rejected – 'unknown SYS-ID'
T7	AF	personal_data = yes, DPO not signed	Invalid	Rejected – 'DPO missing'
T8	AF	CISO signature missing	Invalid	Rejected – 'signature'
T9	Finding	cvss 6.1, severity Medium, sys_id in scope	Valid	Accepted; window 90
T10	Finding	cvss 0.0 or 10.0	Boundary	Accepted; severity Low / Critical
T11	Finding	cvss 10.1	Invalid	Rejected
T12	Finding	sys_id not in engagement scope	Invalid	Rejected; out-of-scope alert (Task 5)
T13	Finding	personal_data_exposed = yes	Boundary	Accepted but routed to DPO; disclosure rule D5

8.5 Evidence of integration

- D1 scope list → D2 scope hash → Verification rule V5 (Task 5).
- D3 JSON → can_disclose() (Task 6) uses severity and window_days; its sys_id is checked against D1/D2.
- D5 output → pre-engagement checklist item 9 (Task 5) and lab containment proof (Task 7).
- D1 field personal_data_involved → DPO gate (Task 4 LC-8).

Task 9 – Integrate, Test and Refine the Framework

9.1 Integrated framework

The integrated framework (UASAP-EF v1.0) joins the components in this order: Request → Scope check (Task 5) → Legal/data gate (Task 4) → Authorization and signature (Task 6, D1) → Pre-engagement checklist (Task 5) → Lab rehearsal (Task 7) → Live test under code of conduct (Task 3) with threat model scenario from Task 2 → Finding report (D3) → Coordinated disclosure (Task 6) → Closure (D6). The blueprint in Figure 1 is the reproducible map and the document library plus audit log are the shared data.

9.2 Walkthrough – ENG-2026-LMS-001

Step	Event	Component used	Output
W1	Dean of IT Faculty requests test of LMS staging (SYS-007) and read-only checks on SYS-004 before upgrade	Task 6 step 1	Request R-0231
W2	Governance Officer checks register, blackout dates (no exams) and classifies threat scenario as 'grey-hat/script-kiddie style web attack'	Tasks 2, 5	Screened
W3	LMS holds personal data on SYS-004 → DPO review; condition: test accounts only; synthetic data on SYS-007	Task 4 (LC-8)	DPO note
W4	CISO approves; AF-2026-014 signed by Dean, CISO, lead tester; logged	Task 6, D1	LOG-0231
W5	RoE generated; scope hash computed; pre-engagement checklist items 1–13 completed	Task 5, D2	Checklist signed
W6	Testers rehearse in lab: DVWA target 192.168.56.102; Operation 1 shows isolation OK	Task 7	Lab Record D5
W7	Live test on SYS-007 in window; every target IP passes CR-2; commands logged	Tasks 3, 5	Command log

W8	Tester finds reflected XSS in course search (SYS-007); evidence masked	Task 3 CR-5	Finding FND-…-01 (JSON)
W9	Report sent privately to owner; severity Medium; window 90 days	Task 6	Disclosure notice D4
W10	Owner fixes in 25 days; tester retests in lab and on staging	Tasks 6, 7	Status FIXED_VERIFIED
W11	can_disclose = ADVISORY_ALLOWED; internal advisory published (no exploit details)	Task 6	Advisory
W12	Closure: evidence destroyed; D6 signed; AF status COMPLETED	Task 4 LC-10	Closure certificate

9.3 Systematic test cases

ID	**Category**	**Scenario**	**Expected framework response**	**Result (v1.0)**
TC-01	Missing authorization	Tester starts scan with no AF	CR-1 blocks; incident logged	Pass
TC-02	Missing authorization	AF exists but status REQUESTED, not APPROVED	Blocked (V1)	Pass
TC-03	Missing authorization	AF signed by system owner only	Rejected (V2/D1 signature rule)	**Fail – accepted by early form (see P1)**
TC-04	Out-of-scope	Scan of whole /24 subnet	Rejected by T1/T2	Pass
TC-05	Out-of-scope	Finding for SYS-005 not in scope	Flagged; disclosure blocked	**Fail – report accepted (see P2)**
TC-06	Legal conflict	Test touches SYS-004 with real student records	DPO gate; use test accounts; stop if >5 records	Pass

TC-07	Legal conflict	External assessor in the USA requests access	CFAA conditional check + contract + NDA	**Fail – no rule for foreign assessors (see P3)**
TC-08	Legal conflict	Mail provider is cloud-hosted	Third-party consent LC-11	Pass
TC-09	Delayed disclosure	Owner silent past window (Critical)	Board decision rule D2	Pass
TC-10	Delayed disclosure	Owner requests second extension	Only one extension allowed	**Fail – not defined (see P4)**
TC-11	Expired authorization	Retest needed on day 35	Renewal needed (V4)	Pass

9.4 Problems encountered and refinements

No.	Problem found	Refinement (v1.1)
P1	Early AF template allowed approval with one signature (TC-03)	AF now requires system owner + CISO + lead tester; validate_af() checks all three
P2	Findings were not checked against the scope list (TC-05)	Added sys_id ∈ scope check to Finding Report validation (T12) and a flag in the workflow
P3	No rule for external assessors based abroad (TC-07)	Added V8 (contract, NDA, legal clearance) and conditional CFAA check in legal gate
P4	Extension of remediation window was undefined (TC-10)	Rule: one extension, max 50% of window, approved by Board; log entry required
P5	Walkthrough showed authorization waiting for DPO took longest (2 days)	Added DPO review in parallel with CISO screening and a 1-day SLA
P6	Lab record was not linked to engagement ID	D5 now carries the engagement ID and hash, checklist item 9 added

After refinement, all 11 test cases pass (re-run result 11/11). The corrected framework is UASAP-EF v1.1, whose changes are reflected in Tasks 5, 6 and 8 in this report.

Task 10 – Scalability and Governance Evaluation

10.1 Scenarios

Scenario	Systems	Testers	Engagement requests per month	Approvers
Small programme (one department)	8	6 internal	4	1 (CISO)
Large programme (whole university + external assessors)	120	50 internal staff + 15 external	40	1 (CISO) in baseline design

10.2 Experiment setup (reproducible)

A simple discrete-event simulation (Python, random seed 42, 400 requests per run) models the approval queue. Requests arrive randomly (Poisson), pass through sequential reviews (owner, CISO, plus DPO/Legal where needed), and each review takes an average of 3 working hours (exponentially distributed). Time is counted in working hours (160 hours per month). Two other processes were counted by step-counting the framework: scope verification steps and requests cleared per month as a share of demand. The code is in Appendix A.

10.3 Results

Process / measure	Small	Large baseline	Large refined
1. Authorization – mean approval turnaround (working hours)	6.6	≈ 1071 (queue unstable; backlog grows)	4.2 (Tier-1: 1.5; Tier-2/3: 10.5)
2. Scope verification – steps per engagement	7	10 (7 + 3 for external vetting)	4 internal / 6 external
3. Requests cleared per month (% of demand)	100%	≈ 44% (one approver, 3 stages ≈ 9 h per request → 17.8 requests per month vs 40 demand)	≈ 100%

Disclosure – steps to closure	6	6	6 (but severity-tiered windows, see Task 11)

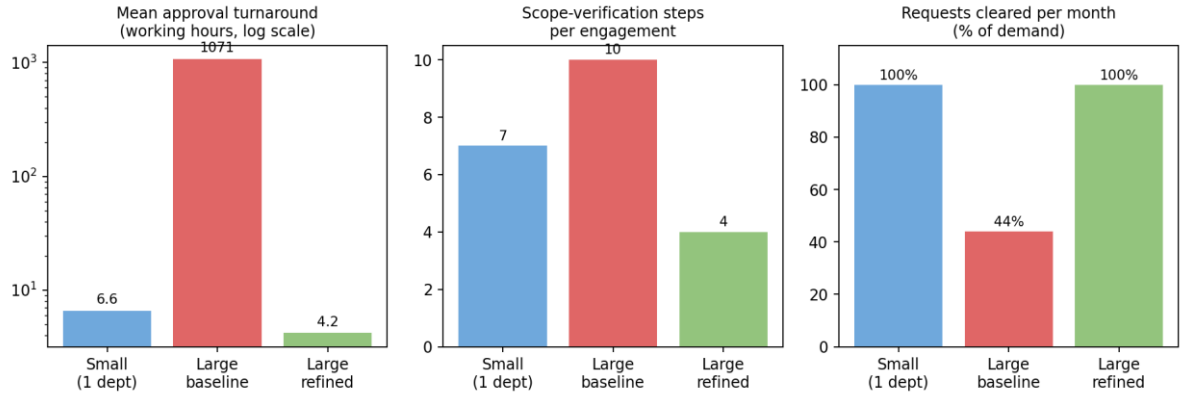


Figure 2: Small vs large programme – measured governance indicators

10.4 Interpretation

- The small programme works with one approver (turnaround 6.6 working hours), so the original design is adequate for the initial scenario.
- In the large programme a single central approver is overloaded: 40 requests per month need about 360 review-hours but only 160 hours are available. The queue grows without limit; therefore DC5 (< 8 hours) fails in the baseline.
- Scope verification took 10 steps because every check was manual against a spreadsheet register, which also lowers coverage because testers wait.
- These results show that the problem is governance structure, not tester numbers.

10.5 Governance refinement based on the evidence

Change	**How**	**Effect**
Risk-tiered approval	Tier 1 (non-personal-data, low/medium criticality, internal testers, standard RoE): approved by System Owner + Governance Officer (3 deputies). Tier 2: CISO. Tier 3 (personal data, critical systems or external assessors): CISO + DPO + Legal.	About 70% of requests go through one-stage approval; turnaround drops from ≈1071 h to 4.2 h and DC5 passes.

Automated scope check	Scope register becomes a database; validate_af() and CR-2 check IDs, IPs and dates automatically	Verification steps 7 → 4 (internal) and 10 → 6 (external)
Standard RoE templates	Pre-approved technique lists for common test types	Fewer questions per request
Delegation and quarterly audit	Deputies approve; Governance Board audits 10% of Tier-1 approvals each quarter	Keeps control while removing bottleneck

This refinement was folded into UASAP-EF v1.2 and is the basis for the changed-requirement design in Task 11.

Task 11 – Defend the Framework Under a Changed Requirement

Changed requirement: continuous and third-party assessments, stricter data-protection rules, shorter disclosure timeline, and the framework must remain easy to govern and extend.

11.1 Component decisions

Component	Decision	Reason
Hacker threat model (Task 2)	**Modify**	Add 'third-party assessor/supply-chain' actor and 'compromised assessor account' as a threat
Code of conduct (Task 3)	**Retain with small modification**	Principles still hold; add rule CR-9 on third-party tooling and data location
Legal mapping (Task 4)	**Modify**	Make DPDP the primary lens; add data-processor contract clauses, cross-border check
Scope & RoE (Task 5)	**Redesign**	One-off RoE per engagement cannot support continuous testing → RoE as living, versioned document with automatic scope diff
Authorization layer (Task 6)	**Redesign (partly)**	30-day AF replaced for continuous programmes by Standing Authorization Agreement (SAA) with 90-day renewal
Disclosure process (Task 6)	**Modify**	Shorter, severity-based timeline
Isolated lab (Task 7)	**Retain**	Still valid for rehearsal; add rule that third-party tools are first run in the lab
Document library (Task 8)	**Modify**	Add SAA, Data-Processing Addendum (DPA) and Assessor Onboarding Checklist; keep existing documents
Evaluation (Task 10)	**Retain**	Re-run with new parameters

11.2 New and modified components

New component N1 – Standing Authorization Agreement (SAA) and continuous-assessment controller

- A Standing Authorization is granted for a fixed list of SYS-IDs and technique classes for 90 days (max), with renewal and monthly review.
- Each test run in the SAA must register a **run ticket** (run-id, SYS-ID, window, tester). The controller (extension of validate_af()) checks the run against the SAA scope hash, window and technique list automatically; anything outside is rejected as in Task 5 T1–T3.
- Any scope change creates an amendment and a new hash (V7); expired SAA blocks all runs.
- Integrates with: scope register (Task 5), audit log (Task 6), code-of-conduct checks (CR-1 to CR-3) and the finding report JSON.

New component N2 – Third-party assessor onboarding and data-protection gate

- Onboarding: contract, NDA, DPA (data-processor clauses under DPDP), proof of competence, background check, insurance, location of staff and tools (CFAA/foreign-law check).
- Data gate: continuous tests use synthetic/masked data where possible; any real personal data needs DPO approval per SAA, encryption at rest and in transit, evidence retention ≤ 30 days; breach/incident notice within 6 hours to CISO (matching CERT-In timing).
- Assessor accounts are time-limited, MFA-protected and reviewed monthly.

Modified component M1 – Shorter disclosure timeline

Severity	**Baseline window (Task 6)**	**Revised window**	**Rule**
Critical	30 days	**14 days (immediate mitigation within 72 hours)**	Board notified at day 7
High	60 days	**30 days**	One extension of 7 days max
Medium	90 days	**45 days**	One extension of 15 days max
Low	120 days	**60 days**	Fix in normal release
Active exploitation	Immediate	Immediate	D4 – CERT-In within 6 hours

Vendor non-response	90 days	45 days	D3 rule

Integration: window_days in the Finding Report (D3) is now looked up from this table; can_disclose() reads the same value, so no other code or document needs to change. This shows the extensibility of the design (DC8).

11.3 Revised workflow

```
Assessor onboarding (N2) -> SAA signed (N1) -> per-run ticket -> automatic scope/window/technique check
  -> test (lab rehearsal for new tools) -> Finding JSON (D3, revised window) -> disclosure (M1) -> monthly SAA review
```

11.4 Defence using evidence

Evidence	**What it showed**	**How the final design uses it**
Walkthrough (Task 9)	Delays arose at DPO review and out-of-scope findings were initially accepted	DPO gate placed in parallel and mandatory for third parties; finding scope check is automatic in SAA runs
Test cases TC-03, TC-05, TC-07, TC-10 (Task 9)	Gaps in signatures, scope, foreign assessors and extensions	All four fixed in v1.1 and carried into the revised design
Scalability evaluation (Task 10)	Single approver fails above ≈ 18 requests/month; tiering gives 4.2 h turnaround	SAA reduces approvals further: one approval per 90 days instead of one per test, so continuous testing does not recreate the bottleneck
Legal mapping (Task 4)	DPDP carries the highest penalties (up to Rs 250 crore); evidence must be erased	Revised data gate, DPA, 30-day evidence retention, 6-hour incident notice

Disclosure process (Task 6)	Coordinated disclosure with decision rules works; windows can be changed through one table	Revised timeline (14/30/45/60 days) is applied without redesign

11.5 Re-test of the revised framework

Test	Scenario	Expected	Result
R-1	Continuous run after SAA expiry	Blocked	Pass
R-2	Run against SYS not in SAA	Rejected (out-of-scope)	Pass
R-3	Third-party assessor without DPA	Onboarding fails; no SAA issued	Pass
R-4	Critical finding, owner silent on day 8	Board notified at day 7; decision at day 14	Pass
R-5	Real personal data found in evidence	Purge, DPO, 6-hour notice	Pass

11.6 Remaining trade-offs and limitations

Trade-off / limitation	Explanation	Future improvement
Speed versus control	Standing authorization reduces approvals but a compromised or careless assessor could act inside the 90-day period	Real-time monitoring of run tickets, anomaly alerts, shorter SAA renewal (30 days) for critical systems
Shorter disclosure windows versus fixing capacity	14 days for Critical may be unrealistic for legacy systems and could push staff to rushed patches	Virtual patching/compensating controls, resource buffer, automatic risk-acceptance review
Manual elements remain	DPO and Legal reviews and signatures are human-dependent; DPDP Rules and case law are still evolving	Digital-signature workflow, regular legal review, link register to ticketing system

Simulation limits	The evaluation used a simple queue model and design-level lab, not production data	Pilot on 20 systems for one quarter and tune with real metrics
Third-party trust	Contracts cannot prove how an assessor handles data	Assessor audits, evidence-vault hosted by the university

11.7 Conclusion

UASAP-EF answers the eight enquiry questions of Task 1 and meets the eight design criteria: authorization-first (TC-01/02), legal traceability (Task 4 table), containment (host-only lab), consistency (Tasks 2–3 rules), scalability (4.2 h turnaround), auditability (single log), usability (13-item checklist) and extensibility (Task 11 changes needed only one new component group and three modified items). The framework clearly separates what is authorized (signed AF/SAA), what is legal (IT Act, DPDP, CFAA mapping) and what is appropriate (code of conduct and Governance Board) and is therefore suitable for the university's present and future programme.

References

- Government of India. The Information Technology Act, 2000 (as amended by the IT (Amendment) Act, 2008) – sections 43, 43A, 65, 66, 66C, 66D, 69, 70, 72, 72A, 84B, 84C.
- Government of India. The Digital Personal Data Protection Act, 2023.
- CERT-In. Directions under section 70B(6) of the IT Act relating to information security practices, procedure, prevention, response and reporting of cyber incidents (28 April 2022).
- United States Code. 18 U.S.C. § 1030 – Computer Fraud and Abuse Act.
- US Department of Justice (2022). Policy for charging cases under the CFAA (good-faith security research).
- Van Buren v. United States, 593 U.S. 374 (2021).
- EC-Council. Certified Ethical Hacker (CEH) course material – hacker types and ethical hacking phases.
- ISO/IEC 29147:2018 Vulnerability disclosure; ISO/IEC 30111:2019 Vulnerability handling processes.
- Oracle VirtualBox User Manual – Host-only and NAT networking. Kali Linux documentation.
- FIRST. CVSS v3.1 specification.

Appendix A – Evaluation code (Task 10)

```
import random, heapq, json
random.seed(42)
def sim(lam_per_month, servers, mean_review_h, n=400, stages=1):
   # working hours per month = 160; arrivals Poisson; each request needs `stages`
sequential reviews
   t=0.0; free=[0.0]*servers; waits=[]
   for _ in range(n):
      t+=random.expovariate(lam_per_month/160.0)
      arrive=t; cur=arrive
      for s in range(stages):
         i=min(range(servers), key=lambda k:free[k])
```

```
            start=max(cur,free[i]); dur=random.expovariate(1/mean_review_h)
            free[i]=start+dur; cur=start+dur
        waits.append(cur-arrive)
    return sum(waits)/len(waits)
res={}
# Small: 1 dept, 8 systems, 6 testers, 4 requests/month, 1 approver (CISO), 2 stages (owner, CISO)
res['small']=sim(4,1,3,stages=2)
# Large baseline: 120 systems, 50 staff + 15 external, 40 requests/month, single central approver, 3 stages(owner, CISO, DPO/legal)
res['large_before']=sim(40,1,3,stages=3)
# Large refined: risk-tiered; 70% Tier1 delegated (1 stage, 3 deputies), 30% Tier2/3 3 stages with 3 reviewers
t1=sim(28,3,1.5,stages=1); t23=sim(12,3,3,stages=3)
res['large_after']=0.7*t1+0.3*t23
res['tier1']=t1; res['tier23']=t23
print(json.dumps(res,indent=1))
```